DOCUMENT 05

LEDGER ZERO

Security Self-Assessment Report

Permission-Tier Architecture · Risk Register · Mitigation Protocols

- **Evaluation Section: Security & Compliance (30% Scoring Weight)**
- **Topic E: SME Finance Copilot — Human-in-the-Loop Governance**
- **Key Controls: RBAC · PostgreSQL RLS · HITL Approval Gate · Audit Log**

Tsinghua University PBCSF & WeBank Global FinTechathon

International Track — Topic E: SME Finance Copilot

October 2026

SECTION 1 — Executive Summary & Security Philosophy

1.1 The Trust Imperative in SME Financial Systems

Small business owners entrust LEDGER ZERO with their most sensitive operational data: daily cash balances, customer identities, supplier invoices, and staff payroll. Security is therefore not an optional extra — it is the foundational prerequisite of user adoption. A single data leak, an incorrect balance figure, or an unauthorized payment action could destroy the business and permanently damage customer trust.

Core Security Principle — Deterministic Financial Decoupling:
Generative AI interprets user intent and drafts action proposals in natural language. However, AI is architecturally prohibited from performing arithmetic on financial balances, modifying database records, or issuing payments without passing through the Human-in-the-Loop (HITL) approval gate and the deterministic financial engine.

SECTION 2 — Permission-Tier Implementation & RBAC Matrix

2.1 Role-Based Access Control Architecture

LEDGER ZERO implements a strict 4-tier RBAC model enforced simultaneously at three layers: (a) UI route guards preventing page access, (b) API middleware validating JWT role claims, and (c) PostgreSQL RLS policies blocking unauthorized queries at the database engine level.

Role	Pages Accessible	AI Execution Authority	DB Mutation Rights	Key Restriction
Owner	ALL pages including /admin, /financing, /team, /audit-logs	Approve or reject any AI action — unlimited authority	Full: approve payables, write-off invoices, configure bank APIs	Cannot delete historical audit log entries
Manager	/inventory, /invoices, /pos, /transactions, /reports, /receivables, /payables	Routine operations: stock restock, AR reminder dispatch only	Create/update invoices & stock; cannot configure system settings	Cannot access /admin or /financing
Cashier	/pos register only — all other routes return 403	No AI access at all	POS checkout only — cannot view, create, or delete any other record	Strictly isolated to single register terminal
Viewer	/dashboard, /reports, /audit-logs (read-only)	Conversational chat queries only — no task execution	None — all writes blocked at DB level	Cannot export data or view customer contact details

2.2 HITL Approval Gate — AI Cannot Execute Without Owner Sign-Off

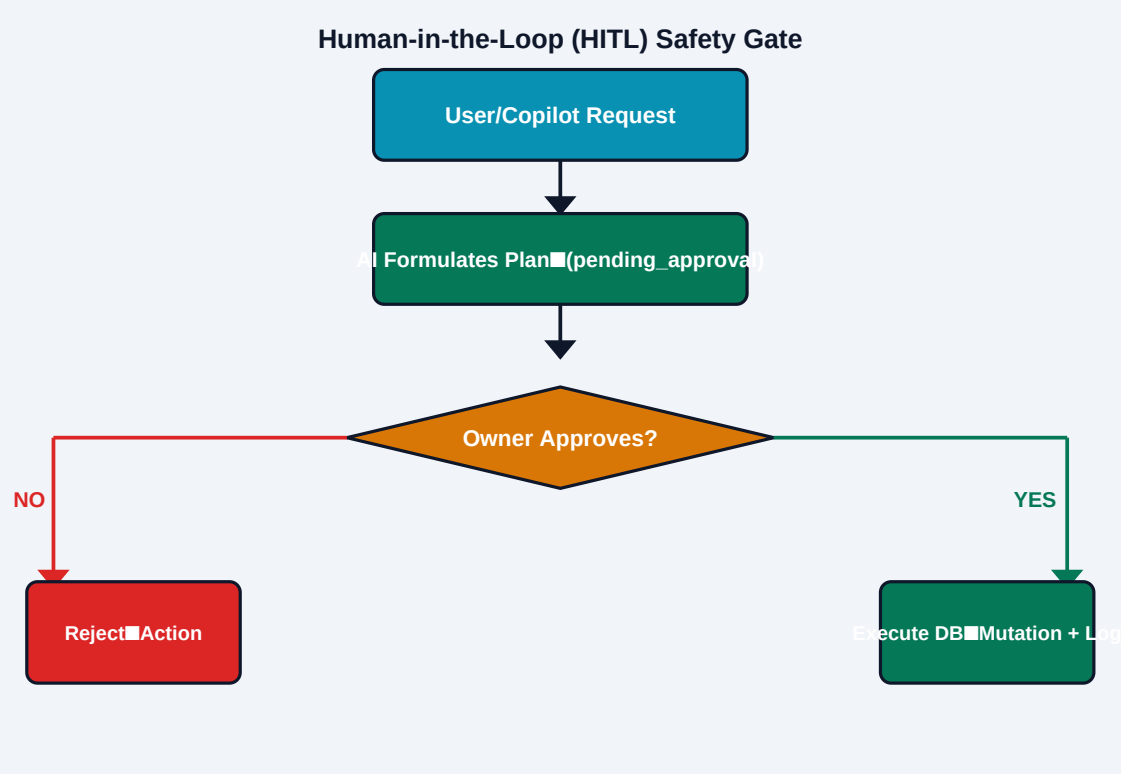

Fig. — Human-in-the-Loop Safety Gate — mandatory before any DB mutation

When the AI Copilot identifies a required action, it creates an ActionTask record with status = 'pending_approval' and surfaces it in the Action Center. The server-side API route rejects any execution request with status ≠

approved regardless of the caller's claims.

SECTION 3 — Known-Risk Register & Technical Mitigations

3.1 Full Risk Register with Severity Ratings

Risk ID	Threat / Vulnerability	Severity	LEDGER ZERO Mitigation	Residual Risk
R-01	**LLM Hallucination of Financial Balances — AI model generates incorrect monetary figures**	CRITICAL	Zero LLM math policy: all amounts computed by TypeScript integer engine (src/lib/finance/engine.ts). AI output is text-only narrative.	Very Low
R-02	**Prompt Injection / Jailbreak — malicious input attempts to override system instructions**	HIGH	Strict Zod schema validation on all action inputs. Unverified action types are rejected with 400 error. System prompt is server-side only.	Low
R-03	**Multi-Tenant Data Leakage — business A queries business B's data**	CRITICAL	PostgreSQL Row-Level Security enforces business_id = auth.uid() at kernel level. Even a compromised application layer cannot bypass RLS.	Very Low
R-04	**Unauthorized AI Mutations — AI executes financial actions without approval**	CRITICAL	HITL mandatory approval gate. Server API returns 403 if ActionTask.status ≠ 'approved'. No bypass path exists.	Very Low
R-05	**Audit Log Tampering — actor attempts to delete or modify transaction history**	HIGH	Audit log table has REVOKE DELETE, UPDATE on audit_logs FROM authenticated; Only INSERT is permitted.	Low
R-06	**Weak API Key Exposure — AI API key leaked from environment**	MEDIUM	Keys stored in Supabase encrypted system_settings table (AES-256). Never sent to client browser. Masked in admin UI.	Low
R-07	**Brute-Force Login — automated credential stuffing**	MEDIUM	Supabase Auth provides built-in rate limiting (max 5 attempts / min), CAPTCHA option, and email verification.	Low
R-08	**Session Hijacking — stolen JWT used after logout**	MEDIUM	Short-lived JWT (1h access token), refresh token rotation, and server-side session invalidation on logout.	Low

SECTION 4 — Data Security, Encryption & Regulatory Compliance

4.1 Data Classification & Encryption

Data Category	Classification	Encryption	Access Control
API Keys & Secrets	TOP SECRET	AES-256 at rest via Supabase Vault; TLS 1.3 in transit	Server-side only; never exposed to browser or logs
Customer PII (Name, Phone, Address)	CONFIDENTIAL	AES-256 at rest in PostgreSQL; TLS in transit	Owner and Manager roles; Viewer role sees masked values
Financial Transactions & Balances	CONFIDENTIAL	Database-level encryption; integer minor units prevent precision leakage	Business-scoped via RLS; audit log on all mutations
Invoice & Payment Records	SENSITIVE	Encrypted at rest; append-only ledger design	Role-gated; Cashier cannot view historical invoices
Audit Logs	SENSITIVE	Encrypted at rest; non-deletable	Viewer role has read access; no role has DELETE access

4.2 Regulatory & Standards Compliance

Standard / Regulation	Applicability	LEDGER ZERO Compliance Implementation
China PIPL (Personal Information Protection Law)	Customer PII stored and processed in the system	Data minimization; consent-based collection; encryption at rest and in transit; access logging
GDPR (EU General Data Protection Regulation)	International track; EU team members may be involved	Right to erasure (soft-delete with audit retention); data portability export; consent records
Chinese VAT Standards	Invoice generation for Chinese SMEs	6% VAT rate preset; invoice fields comply with China tax bureau requirements; integer CNY arithmetic
PCI-DSS Basics	Payment method recording (WeChat Pay, Alipay, Cash, Bank Card)	Payment method type stored; full card/wallet numbers never collected or stored in LEDGER ZERO